Controles de Calidad y Seguridad en CI/CD

1. Objetivo

Revisar el flujo de integración y despliegue para identificar riesgos de calidad, seguridad y operación, y proponer controles que fortalezcan la entrega continua.

2. Revisión del flujo CI/CD

El flujo de integración y despliegue debe incluir al menos estas etapas:

- Recepción del cambio y validación del origen.
- Compilación y análisis de dependencias.
- Ejecución de pruebas automáticas.
- Validación de seguridad estática y dinámica.
- Construcción de artefactos reproducibles.
- Despliegue controlado por entorno.
- Verificación post-despliegue.

3. Controles de calidad

- Ejecución de pruebas unitarias, integración y end-to-end en cada pull request.
- Validación de cobertura mínima por servicio o módulo crítico.
- Análisis estático de código para detectar duplicación, vulnerabilidades y defectos.
- Control de calidad del artefacto final antes del despliegue.
- Revisión de cambios con estándares de estilo y calidad definidos.

4. Controles de seguridad

- Escaneo de dependencias para detectar bibliotecas con vulnerabilidades conocidas.
- Escaneo de secretos para evitar filtración accidental en repositorio o logs.
- Validación de permisos mínimos y políticas de acceso por entorno.
- Firma digital y verificación de artefactos antes de producción.
- Revisión de configuración de infraestructura para evitar exposición innecesaria.
- Análisis de riesgos de despliegue con aprobación por parte de responsables.

5. Controles operativos

- Aprobar despliegues por ambiente con criterios definidos por criticidad.
- Mantener rollbacks automatizados en caso de fallo.
- Registrar evidencia del despliegue con versionado y trazabilidad.
- Establecer monitoreo de salud, errores y tiempos de respuesta luego del lanzamiento.
- Definir criterios de aceptación para cada entorno antes de promoción a producción.

6. Recomendaciones

- Separar flujos de rama por entorno y permisos.
- Automatizar validaciones de seguridad en cada etapa del pipeline.
- Mantener políticas de calidad y seguridad en repositorio y revisión continua.
- Realizar simulacros de despliegue para validar controles y tiempos de recuperación.

7. Conclusión

Un pipeline de CI/CD robusto requiere controles de calidad, seguridad y operación integrados desde el inicio. Esto reduce errores en producción, acelera entregas con menor riesgo y mejora la confianza en cada despliegue.